ISMS-COMPLIANCE-GOVERNANCE

ISMS·ISMS-P·간편인증과 정보 보호 컴플라이언스

연관 기출 · 131-3-6, 138-3-6, 140-4-5, 132-4-6, 129-3-6

한눈에 이해

법과 인증 요구를 체크표로 만 남기지 않고 자산·위험·책임자·운영 증거·개선으로 이어 관리합니다.

정의와 핵심 원리

정보 보호컴플라이언스는적용 법령·계약·내부 정책·표준의 요구를 식별하고 통제를 구현·검증·개선하는활동입니다. ISMS는 정보 보호 관리체계인증, ISMS-P는 개인정보 처리 단계 보호까지 포괄하는통합 관리체계인증입니다.

• 관리 흐름은 경영진지원·범위·조직 정책수립 → 자산·위험식별평가 → 보호대책선정·구현 → 운영 점검·감사 → 결함개선·재평가입니다. 인증 범위 밖시스템·위탁·개발·운영 책임과 예외를 명시합니다. 정책은 의도와책임을 정하고 절차·지침은 실제 수행방법으로 연결합니다.

• 기술 통제만 아니라교육·인사·공급자·사고 대응·업무연속성·개인권리·물리보호를 다룹니다. 증거는 접근 권한 승인·회수, 취약점조치, 백업 복원, 로그 점검, 사고훈련등실제 운영 기록이 어야합니다. 인증서가 사고0을 보장하지 않습니다.

• ISMS 의무 대상과 간편인증 적용 기준·항목수·최신 인증 영역은 법과 고시의 시점별원문으로 확인해야 합니다. 2023안내서·2024간편항목 목록을 2026변경후요건이라 사칭하지 않습니다. 강화방안은NHI·클라우드·AI·공급망의실제 범위 반영, 위험 기반증빙과지속감시라는제안으로구분합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
ISMS	정보 보호 관리·보호대책	인증 범위·의무 대상 확인
ISMS-P	개인정보 처리 단계포함	권리·생애주기증빙
준수운영	법·계약·정책매핑	통제 실행·책임·개선

적용 예제

신규 AI SaaS의 준수 검토

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 기존 인증 조직이 외부AI서비스를 추가 하는가정

1. 개인정보·비밀·모델입출력 흐름과 계약을 새범위로 검토합니다.
2. 적용 요구를 통제·소유자·증거·점검 주기에 매핑합니다.
3. 권한·유출·보관·사고통지·종료 삭제를 시험합니다.
4. 인증 범위 변경과 잔여위험을 정식절차로 관리합니다.

결과·해석: 기존 인증을 신규서비스전체의포괄보증으로 오해하지 않습니다.

전제·주의: 공식누리집소개와자료 목록만 확인;2026최신세부인증 항목·의무 기준·간편대상 전문은 미열람입니다.

답안 골격과 혼동 방지

준수필요성 → 법·정책·통제매핑 → 관리과 정 → ISMS/P/간편구분 → 개선제안

- 미열람항목수를암기표로 확정하지 않습니다.
- 인증을 개인정보 유출면책으로설명하지 않습니다.

내용을 가리고 회상

1. 정책과 절차의 차이는무엇입니까?
2. 준수증거의 실효성을어떻게검증합니까?
3. 인증 범위가 중요한이유는무엇입니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- ISMS-P 공식 누리집 - KISA; 2026 표시 페이지; 확인 2026-11-05.
- 개인정보의 안전성 확보조치 기준 - 국가법령정보센터; 2026-07-01개정표시; 확인 2026-11-05.